LABORATUVAR 5 · GENEL SÜRÜM · Şişeleme Hattı

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad Halit Acet · 230542018 | Grup | Tarih 06.11.2026

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

Üç şart: (1) Bileşen var mı? SBOM'da Component X aranır. (2) Sürüm 2.4 CVE'nin etkilenen aralığında mı? (3) Açık ulaşılabilir mi? Hat ağdan / uzak erişimden erişilebiliyor mu? Üçü de evetse etkiliyoruz; biri hayırsa risk düşer ama karar kaydedilir.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

Hemen durdurmam: önce etki ve ulaşılabilirlik analizi. Ağdan erişilemiyorsa planlı bakım penceresinde yama; ulaşılabilir ve istismar belirtisi varsa önce güvenli duruma alıp kontrollü durdururum. Karar gerekçesiyle kayda geçer.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Doğrudan değil, önce test: canlı hat yerine test ortamı / yedek PLC / simülasyonda denenir. Yedek ve geri dönüş planı hazırlanır, sonra bakım penceresinde uygulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Evet, etkileyebilir (firmware güvenlik mantığına dokunabilir). Yamadan sonra emniyet fonksiyon testi (E-stop, ışık perdesi, STO süresi) tekrarlanır, önceki doğrulama kaydıyla karşılaştırılır, hash / imza kontrol edilir.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Bileşene erişimi segmentle kısıtla (yalnız izinli IP/port), uzak erişimi jump server + MFA arkasına al, izleme ve alarm ekle, USB / mühendislik erişimini kısıtla. Süreli, kayıtlı ve yama planına bağlı olsun.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.